WEB PLATFORM

Web Security Essentials

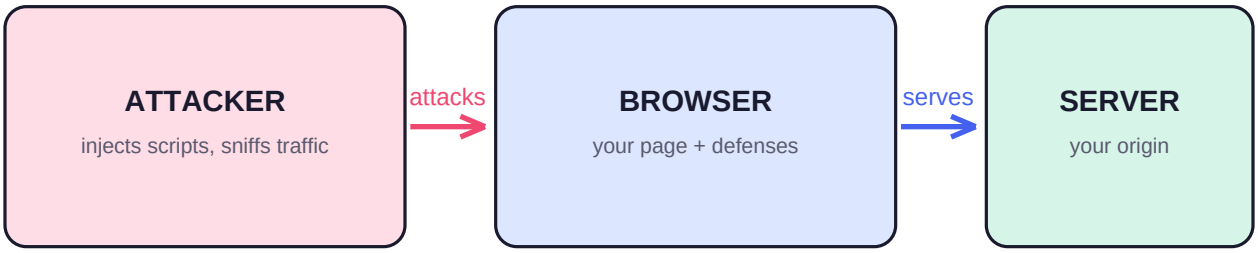
CSP, CORS, cookie flags, and HTTPS —
the browser's defense layers, explained visually.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

The Browser Threat Model

Your page runs attacker-influenced content: user input, third-party scripts, network foes.



SAME-ORIGIN POLICY

the foundation: origins can't read each other's data by default

Every defense below is a refinement of one idea: decide what each origin is allowed to do.

STEP 2/6

HTTPS Everywhere

TLS gives confidentiality, integrity, and server authentication.

CONFIDENTIALITY

encrypted — no eavesdropping

INTEGRITY

tamper-evident — no silent edits

HSTS

Strict-Transport-Security: browser refuses plain HTTP from now on

MIXED CONTENT

HTTPS page loading HTTP subresources -> blocked or warned

STEP 3/6

Content Security Policy

A whitelist, delivered in a header, of what the page may load and run.

Content-Security-Policy: default-src 'self'; script-src 'self' cdn.example

only your origin + that CDN may run scripts

BLOCKS XSS PAYLOAD

injected <script> from evil.com -> refused

REPORT-ONLY MODE

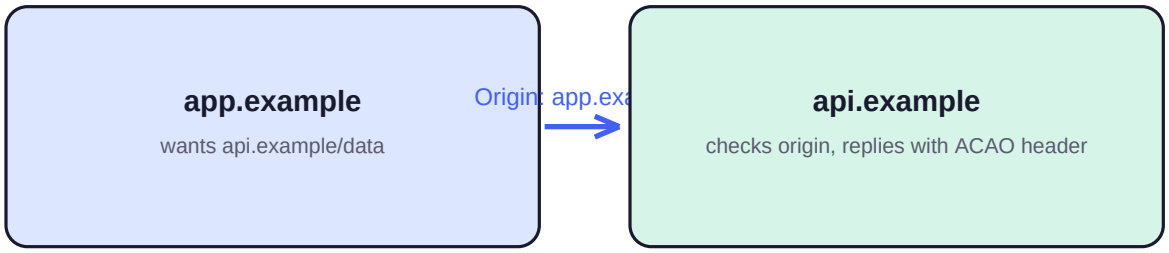
test policies without breaking the site

Start with report-only, watch violation reports, then enforce. Nonces beat 'unsafe-inline'.

STEP 4/6

CORS: Who May Read Your Responses

The server opts in to cross-origin reads via Access-Control-Allow-Origin.



PREFLIGHT (OPTIONS)

non-simple requests ask permission first; server must answer

NEVER ACAO: * with credentials

reflecting arbitrary origins + cookies = account takeover

STEP 5/6

Cookie Flags

Three attributes turn a tracking token into a hardened session cookie.

HttpOnly — invisible to document.cookie — XSS can't steal it

Secure — sent only over HTTPS — no plaintext leaks

SameSite=Lax/Strict — not sent on cross-site requests — CSRF killer

RECIPE

```
Set-Cookie: sid=...; HttpOnly; Secure; SameSite=Lax; Path=/
```

STEP 6/6

Secure Defaults Checklist

The headers and habits that stop 90% of web attacks.

HTTPS + HSTS	encrypt everything, pin the upgrade
CSP enforced	script-src whitelist, no unsafe-inline
CORS minimal	exact origins only; no wildcard with credentials
Hardened cookies	HttpOnly + Secure + SameSite
X-Content-Type-Options: nosniff	stop MIME-sniffing attacks
Input handling	validate server-side; encode output; parameterize queries

STEP ✓/✓

Key Takeaways

Web Security — Remember

- The same-origin policy is the foundation: origins are isolated by default.
- HTTPS everywhere plus HSTS gives confidentiality, integrity, and upgrade pinning.
- CSP whitelists executable content — the strongest practical XSS mitigation.
- CORS is the server opting in to cross-origin reads; never wildcard origins with credentials.
- HttpOnly + Secure + SameSite cookies resist theft and CSRF.
- Layer the defaults: HSTS, CSP, tight CORS, hardened cookies, nosniff, server-side validation.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev